

Note de partage communautaire

Incident : INC-2026-0302 · **Classification** : TLP:AMBER · **Version** : 1.0 du 9 octobre 2026 · **Auteurs** : cellule CTI (Marc BOHOUSSOU, [Nom 2], [Nom 3])

1. Principe

Partager ce qui aide les autres à se défendre, sans désigner la victime, sans prévenir l'attaquant et sans diffuser d'information douteuse. Trois filtres sont appliqués à chaque élément : **identifie-t-il Helios Energy ? est-il fiable (cote A1 à B2) ? sa diffusion gêne-t-elle la remédiation ou l'enquête ?**

2. Ce qui est partagé, et sous quelle classification

Classification	Destinataires	Contenu	Pourquoi
TLP:GREEN	Communauté : CERT sectoriel de l'énergie, communautés MISP de confiance	Empreintes de BIN-01, BIN-02, BIN-03 (n°1 à 9) et des charges (n°10, 11). Domaines et adresses de livraison et de commande (n°13, 14, 19, 20, 21, 29, 31). Certificat CN=update-service (n°33). Noms de persistance : tâche MicrosoftEdgeUpdateTaskMachine, valeur WinTelemetry (n°36, 38). Les 25 techniques ATT&CK. Les règles Sigma comportementales (01, 03, 06, 07, 08, 11, 13, 15)	Fiables, propres à l'attaquant, sans lien avec la victime. C'est ce qui protège le plus vite les autres opérateurs
TLP:AMBER	ANSSI et partenaires nommés ayant besoin d'en connaître	Tout le contenu GREEN, plus : chronologie détaillée, adresse d'exfiltration (n°24), infrastructure d'hameçonnage (n°15, 23, 30, 34), infrastructure de repli (n°16, 22), jugement d'attribution avec sa cote B3, indicateurs cotés B3 à C3 signalés comme non corroborés	Utile à l'autorité et aux pairs directs, mais trop incertain ou trop contextuel pour une diffusion large
TLP:AMBER+STRICT	Helios Energy uniquement	Noms d'hôtes (comptabilite-07, srv-fichiers-02, dc-01, n°40), plan d'adressage interne, adresse n°25 (probable machine de la victime), mémo du SOC, état de la remédiation, matrice CID	Décrit les faiblesses de l'entreprise pendant qu'elle se répare
TLP:RED	Cellule de crise, personnes nommées	Volume et contenu des données exfiltrées, éléments de la plainte, échanges avec les autorités	Engage la responsabilité juridique ; le secret de l'enquête s'applique

3. Ce qui n'est pas partagé

Élément	Raison
helios-energy-portal[.]test et son URL (n°17, 32)	Le nom de domaine révèle l'identité de la victime. Transmis à l'ANSSI seulement
Indicateurs n°27, 28, 35 (cotes C4 et D4)	Non observés ou non corroborés. Les diffuser polluerait les bases des autres et propagerait une attribution fragile
Domaine n°18, RDP n°26	Rôle non éclairci, contradiction avec l'alerte 7
Compte svc-backup-temp (n°37)	Nom choisi pour cet environnement : faible valeur pour un tiers. La règle générique 13 est partagée à la place
Le nom « FIN7 »	Notre jugement porte sur un cluster non nommé. Diffuser un nom de groupe créerait une fausse certitude chez les destinataires

4. Modalités

- Quand** : après le confinement. Publier les serveurs de commande pendant que l'attaquant est encore présent lui signalerait qu'il est découvert.
- Comment** : depuis MISP, par le niveau de distribution et les étiquettes TLP posées sur chaque attribut ; export STIX 2.1 filtré, sans les attributs AMBER+STRICT. Chaque indicateur part avec sa cote Admiralty, sa source et sa date de collecte.
- Avant envoi** : retirer le domaine de la victime de la règle Sigma 05, relire le bundle pour vérifier qu'aucun nom d'hôte interne n'y figure.
- Durée de vie** : les adresses IP perdent leur valeur en quelques semaines ; les techniques et les règles comportementales restent utiles. Une date de fin de validité accompagne les indicateurs réseau.

5. Correspondance des libellés

Le sujet emploie les libellés français ROUGE, ORANGE, VERT, BLANC. Cette note utilise la norme TLP 2.0 : RED, AMBER (et AMBER+STRICT, limité à l'organisation), GREEN, CLEAR (ex-WHITE). Rien dans ce dossier n'est classé TLP:CLEAR.